GRC103 Module 3 | Lab 2: Ransomware Risk Treatment for Northbridge Community Health

Name: Diana Wanjiru **Registration no.:** C11/26/CGRCE/17188 **Date:** 11 November 2026 **Workbook:** Northbridge_Lab2_Workbook.xlsx

Source: Health Service Executive, *Cyber-attack and HSE response*; last reviewed 1 December 2025; accessed 18 October 2026. https://www2.hse.ie/services/cyber-attack/what-happened/. Northbridge, its budget, prices, insurance terms and changes are fictional classroom assumptions.

Task 1. Assess and prioritise the risks

Separate evidence	Statement
HSE facts (real)	**H1:** A phishing email reached a user on the HSE network in March 2021; opening its attachment downloaded malware, and ransomware was triggered in May 2021. **H2:** The attackers encrypted files and also accessed and copied information; HSE notified 90,000 people and states no ransom was paid.
Northbridge assumptions (fictional)	**N1** an unused supplier workflow is enabled; **N2** recovery has not been tested; **N3** phishing reports have no escalation owner; **N4** essential bookings must continue; **N5** $100,000 Year-1 budget.

ID / risk	Asset	Threat	Weakness	Business impact	Owner	L	I	Score
R1 Service disruption	Booking and clinical systems, 3 clinics	Ransomware encrypts systems (H2)	Recovery untested; bookings must continue (N2, N4)	Clinics cannot book or treat; care delayed	COO	4	5	**20 Critical**
R2 Sensitive-data loss	Patient health records	Data copied and threatened with release (H2)	Late warning; unused supplier path; no owner (N1, N3)	Privacy breach, patient harm, notification and regulatory burden	Data Protection Officer	3	5	**15 High**
R3 Unnecessary supplier exposure	Supplier workflow link	Attacker or compromised supplier uses the enabled workflow	Enabled with no business need (N1)	Extra entry path; supplier incident becomes ours	Head of IT	4	3	**12 High**
R4 Delayed detection	Monitoring and phishing-report process	Opened attachment; intruder stays unseen (H1)	No escalation owner (N3)	Intruder spreads before encryption, as in the HSE March-to-May gap	IT Security Lead	4	4	**16 High**

Why these ratings (score = likelihood x impact; Low 1-4, Medium 5-9, High 10-16, Critical 17-25). R1 = 4 x 5: ransomware against health providers is common and H2 shows it happens; with recovery untested, an outage would stop essential bookings, so impact is the maximum. Critical, so it **cannot be accepted** and must be treated. **R2 = 3 x 5:** an intruder must first get in, so likelihood is medium, but health records are the most sensitive asset and HSE had to notify 90,000 people. High, so **board escalation**. **R3 = 4 x 3:** an enabled, unused path is easy to find and nobody watches it, but alone it is an entry point rather than the loss itself. High, board escalation. **R4 = 4 x 4:** with no owner, reports go unactioned, and H1 shows about two months between the phishing email and encryption; late detection magnifies every other risk. High, board escalation. Scales are classroom scales.

Task 2. Treatment portfolio (Decision 1, recorded 11 Nov 2026)

ID	Option	Cost	Decision / strategy	Risks	Reason
A	Retire unused supplier workflow	$5,000	**Select** - avoidance	R3 (R1, R2 entry)	Removes the exposure completely; cheapest; no business need.
C	Protected backups, restore tests, recovery plan	$30,000	**Select** - mitigation	R1, R2	Only control that keeps essential bookings running; treats the Critical risk.

ID	Option	Cost	Decision / strategy	Risks	Reason
D	Managed detection and escalation	$35,000	**Select** - mitigation	R4, R2	Directly treats delayed detection; limits how much data is copied.
E	Awareness training and reporting process	$10,000	**Select** - mitigation	R4, R1, R2	Targets the phishing route used at HSE; creates the missing escalation owner.
G	Illustrative cyber insurance	$20,000	**Select** - transfer	Financial loss only	Last $20,000 caps the financial tail; does not keep clinics open.
B	MFA and account access review	$25,000	Reject (defer)	R2, R3	A+C+D+E+B = $105,000, over budget; not tied to a stated weakness. Interim: free internal review of admin and dormant accounts.
F	Segmentation and legacy review	$40,000	Reject (defer)	R1, R2	Most expensive and a longer project; no room. Plan for Year 2.
	Total selected	**$100,000**	**Remaining budget: $0**		Buying all seven options would cost $165,000, so trade-offs are unavoidable.

Avoidance (A) stops using a path with no business value. **Mitigation** (C, D, E) lowers likelihood or impact. **Transfer assessed:** G pays money for losses above $25,000 up to $250,000, but it does not restore services, may exclude a claim, and leaves the board accountable for patient care and data protection. Using a managed service (D) likewise does not outsource accountability. **Time-limited acceptance:** accept the residual R2 gap left by deferring B and F until **30 June 2027** (owner: Data Protection Officer; approver, simulated: Board Risk Committee Chair). R1 is Critical and **acceptance is rejected**; it must be treated.

Task 3. Retained financial exposure (option G; fictional terms)

Scenario	Insurer payment = min(max(loss - $25,000, 0), $250,000)	Retained loss	Premium	Total first-year outlay
Covered loss $180,000	min(max(155,000, 0), 250,000) = **$155,000**	$180,000 - $155,000 = **$25,000**	$20,000	**$45,000**
Covered loss $400,000	min(max(375,000, 0), 250,000) = **$250,000** (cap applies)	$400,000 - $250,000 = **$150,000** ($25,000 deductible + $125,000 above the cap)	$20,000	**$170,000**
Claim excluded	$0	Whole loss: $180,000 or $400,000	$20,000	$200,000 or $420,000

If a claim is excluded, **Northbridge bears the loss** (plus the premium already paid); patients carry the harm. Cover is worth buying only if a claim is accepted: the premium is recovered once a covered loss exceeds $45,000 (deductible + premium).

Task 4. Response to the change (Decision 2: restore test fails; paper bookings last 4 hours; B rises to $35,000)

	Decision 1 (initial)	Decision 2 (revised)
Options	A, C, D, E, G = $100,000	A, C, D, E = $80,000; **$20,000 ring-fenced continuity reserve**
What changes	Insurance used the last $20,000.	**G withdrawn.** A premium buys money, not recovery, and a failed restore may complicate any claim. The $20,000 is held for restore remediation and extra manual booking capacity, released only by the board. C becomes top priority: fix, retest, and extend manual booking capacity from 4 hours to a proposed 24 hours.
Deferred	B, F	B (now $35,000), F and G. B cannot fit: A+C+D+E+B = $115,000, and dropping D would leave detection unfunded. Revisit insurance after a passed retest.
Risk owners	R1 COO; R2 DPO; R3 Head of IT; R4 IT Security Lead	Unchanged; reserve owned by the CFO.

	Decision 1 (initial)	Decision 2 (revised)
Escalate to board	Acceptance of residual R2	Withdrawing insurance (full $180,000-$400,000 loss retained); reserve release rule; R1 residual High while restore is unproven; R2 acceptance.

Task 5. 30-day plan (12 Nov - 11 Dec 2026), residual risk and board memo

Action	Owner	Cost	Target	Effectiveness test
Board approves portfolio, reserve, insurance deferral, acceptance	CEO / Board Risk Chair (sim.)	$0	17 Nov	Decision minuted; acceptance form signed
Name phishing-report escalation owner; interim reporting rule (E)	IT Security Lead	in E	13 Nov	Test report from each clinic reaches owner within 1 hour
Retire supplier workflow (A)	Head of IT	$5,000	20 Nov	Config shows disabled; supplier confirms in writing; access attempt fails
Interim review of admin and dormant accounts (staff time)	Head of IT	$0	27 Nov	Reviewed list signed off; dormant accounts disabled
Training and reporting process (E)	IT Security Lead, clinic managers	$10,000	4 Dec	90%+ completion; phishing drill measures report time
Onboard detection and escalation service (D)	IT Security Lead	$35,000	4 Dec	Simulated alert, incl. out of hours, reaches owner within 1 hour
Fix restore; protected backups, plan, retest (C)	Head of IT, witnessed by COO	$30,000	9 Dec	Timed restore of booking and records systems meets agreed time; **not effective until passed**
Extend manual booking capacity to 24 hours (proposed)	COO	$0 (reserve if released)	9 Dec	Unannounced drill at each clinic; essential bookings continue
Day-30 review: re-score from test evidence; report to board	Risk Manager	$0	11 Dec	Scores lowered only where tests passed

Risk	Initial	Residual L x I	Residual	Assumptions (untested controls not treated as proven)
R1	20 Critical	3 x 5	**15 High**	Likelihood credited only if A, D, E tests pass. Impact stays 5 until a restore retest passes; target 3 x 3 = 9 Medium. Not accepted; escalated.
R2	15 High	3 x 4	**12 High**	A closes a path; D limits data copied. No credit for B or F (deferred). Time-limited acceptance below.
R3	12 High	2 x 3	**6 Medium**	Credit only after config check and supplier confirmation; other supplier links not yet reviewed.
R4	16 High	3 x 3	**9 Medium**	New service needs tuning; credit only if the 1-hour alert test passes, otherwise stays 16.

Proposed acceptance: residual R2 (12 High) from deferring B and F. **Owner:** Data Protection Officer. **Expiry:** 30 June 2027. **Review triggers:** confirmed phishing compromise or data-copy alert; failed alert or restore test; insurer, regulator or supplier notice; a price change that brings B or F within budget; mid-term review 31 March 2027. **Simulated approver:** Board Risk Committee Chair. **Conditions:** A, D, E complete and the interim account review done.

Board memo (maximum 300 words)

To: Board of Directors **From:** [Your name], Risk Adviser **Date:** 11 November 2026 **Subject:** Ransomware treatment: decision requested

Decision requested. Approve (1) $80,000 for retiring the unused supplier workflow ($5,000), protected backups with restoration tests and a recovery plan ($30,000), a managed detection and escalation service ($35,000), and targeted awareness training with a reporting process ($10,000); (2) a ring-fenced $20,000 continuity reserve released only by this

board; (3) deferral of insurance, MFA and segmentation; (4) a time-limited acceptance of residual data-loss risk until 30 June 2027.

Budget. $80,000 committed of $100,000; $20,000 held in reserve. Insurance was first selected but is withdrawn: a premium does not restore clinic services, and our restoration test failed. MFA now costs $35,000 and cannot be funded without dropping detection.

Service-continuity priorities. Paper bookings last only four hours. First, fix and retest restoration. Second, extend manual booking capacity to a proposed 24 hours at every clinic. Third, drill the downtime procedure without warning.

Unresolved risks. Service disruption stays High (15) until a restoration retest passes; it cannot be accepted. Data loss stays High (12) while MFA and segmentation wait. Without insurance, Northbridge retains any loss in full, for example $180,000 or $400,000. Managed services and insurance never remove our accountability. Please confirm the reserve rule and the 24-hour target.